IA & CYBERSÉCURITÉ — ITÉRATION 4

Évaluer un modèle de détection SSH

Olivier HIMBLOT • 22 octobre 2026 • Dossier pour le formateur

Compétence : **Évaluer les performances et les limites d'un modèle de détection d'anomalies.**

Critère : mesure sur des données nouvelles au-delà du taux global ; explication des erreurs, biais, dérives et vulnérabilités ; définition des conditions d'exploitation.

Attendu	Preuve et état
Données nouvelles et métriques	Septembre entraîne, octobre évalue ; matrices, précision/rappel et charge documentés.
Erreurs, biais et dérives	Profils de FP/FN analysés ; exclusions, apprentissage court, étiquettes et évolution du SI explicités.
Vulnérabilités	Mécanismes possibles expliqués en annexe ; expériences 4.6 non réalisées, résistance non démontrée.
Conditions d'exploitation	Avis du matin et conditions proposées en annexe ; validation RSSI/SOC et séquence 4.8 encore attendues.
Exécution et reproductibilité	Deux captures VM ; tests de répétabilité et contrôles dans un environnement distinct de l'assistant.

État de la preuve

Données fictives du scénario Hexalp. Rapport rédigé avec assistance à partir des sorties fournies et vérifiées. Le critère est documenté pour l'évaluation temporelle ; il reste **à compléter pour les essais de vulnérabilité et la validation des conditions finales**. Ce dossier ne prétend ni à un déploiement réel ni à une validation globale du modèle.

Fichiers de preuve associés

Dans IA_J4_ressources_apprenant/ia01-j4 : detection_ssh_v2.py ; requirements.txt ; alertes_octobre.csv (239 lignes de données) ; rapport_evaluation.md ; preuves/execution_v2.txt ; preuves/verification_v2.json. Le PDF présente les résultats ; conserver le script et le CSV comme fichiers exploitables joints à la remise.

Organisation : rapport du matin sur les trois pages suivantes ; annexes séparées pour les conditions proposées et les captures.

Rapport d’évaluation — Détection SSH Hexalp

Olivier HIMBLOT — 22 octobre 2026 — Séquence 4.4

Données fictives ; version du matin, rédigée avec assistance à partir des résultats du TP.

Résumé pour Nadia

Le dispositif signale des connexions SSH à examiner, sans bloquer de compte ni de machine.

Sur octobre exploitable, il repère 202 des 211 attaques étiquetées, mais en manque neuf.

Il produit aussi 37 fausses alertes et laisse 14 observations hors analyse faute de mesure.

Les 104 puis 135 alertes hebdomadaires dépassent largement la capacité de 30.

Avis : poursuivre en observation supervisée ; différer la mise en service opérationnelle, le temps de traiter la charge et les angles morts.

Données et préparation

Une observation représente une IP sur une heure. Septembre (14–27/09) : **1 704 lignes, 117 attaques (6,87 %)** ; après suppression de 90 volumes manquants : **1 614 lignes, 108 attaques (6,69 %)**. Octobre (28/09–11/10) : **2 119 lignes, 215 attaques (10,15 %)** ; après préparation : **2 105 lignes, 211 attaques (10,02 %)**.

L’infrastructure change : nouvelle sonde NetFlow en Ko le 29/09, proxy Zabbix le 30/09, nouvelle plage VPN le 01/10, panne de collecte le 04/10, scan autorisé le 06/10. Cela modifie les profils observés et leur interprétation.

La V2 complète les volumes Mo absents par **Ko / 1 024**, puis conserve le choix J3 : exclure les vrais volumes manquants. Les 14 exclusions d’octobre comprennent quatre attaques : elles restent **hors couverture**, sans être comptées comme détectées. L’origine devient externe (0/1). Variables, dans l’ordre : heure, externe, échecs, succès, comptes distincts, durée, volume. Date, IP et décision fail2ban sont exclues des entrées ; l’étiquette sert à entraîner l’arbre et à évaluer, jamais à prédire.

Le script contrôle schéma, valeurs, unités attendues, périodes disjointes et taux de manques ; arrêt au-delà de **10 %**, valeur pédagogique à faire approuver. Le contrôle ne détecte pas toute erreur plausible de mesure.

Protocole et résultats

Graine **42**, arbre de profondeur **3**, Isolation Forest à contamination **0,03**. L'arbre apprend sur 70 % de septembre (1 129 lignes), avec contrôle sur 485 ; Isolation Forest apprend sur tout septembre préparé, sans étiquette. Les modèles restent figés pour octobre ; les étiquettes d'octobre ne servent qu'au bilan. L'alerte finale est leur union.

Changer seulement le fichier dans le script J3 réentraîne et teste sur octobre : le « 99 % » de Sofia ne mesure donc pas le transfert du modèle de septembre vers le futur. Le déséquilibre des classes et les exclusions peuvent aussi masquer des échecs. Ce score peut décrire un calcul interne, mais ne justifie pas une mise en service.

Matrices : **VN/FP/FN/VP** = normales correctement ignorées / fausses alertes / attaques manquées / attaques repérées.

Détecteur, octobre	VN	FP	FN	VP	Précision	Rappel	Alertes S40 / S41
Arbre	1 868	26	17	194	88,18 %	91,94 %	93 / 127
Isolation Forest	1 883	11	175	36	76,60 %	17,06 %	29 / 18
Union	1 857	37	9	202	84,52 %	95,73 %	104 / 135
fail2ban historique	1 894	0	150	61	100 %	28,91 %	61 au total

L'arbre contrôlé en septembre avait **0 FP, 4 FN, 28 VP, 453 VN**, précision 100 %, rappel 87,5 %. Le rappel d'octobre augmente ; sa précision baisse. Sur septembre connu, Isolation Forest affichait 89,80 % / 40,74 % et l'union 95,50 % / 98,15 % (précision/rappel) : ces mesures incluaient de l'entraînement, comparaison descriptive seulement. L'union passe de 45/66 à 104/135 alertes hebdomadaires.

L'union repère 142 attaques non signalées par fail2ban ; fail2ban en repère une qu'elle manque (60 communes). **Conserver les deux moyens.** L'exfiltration du 09/10 à 3 h (8 898 637 Ko, soit 8 690,075 Mo) est retrouvée par Isolation Forest après conversion ; l'arbre l'ignore.

Faux positifs et charge

Cause selon le kit	FP	Qualification à 10 min/alerte
Nouveau proxy Zabbix, quatre comptes distincts, branche de l'arbre	26	4 h 20
Sauvegardes nocturnes atypiques pour Isolation Forest	10	1 h 40
Scanner autorisé, activité à rapprocher de la fenêtre réelle	1	10 min
Total	**37**	**6 h 10**

Il s'agit d'un coût théorique si toutes les fausses alertes sont qualifiées. Les 239 alertes demanderaient **39 h 50** au même tarif ; la capacité de 60 sur deux semaines laisse **179 en excédent**. Le tri par score ne garantit pas que les plus graves seront lues. Vérifier rôles, destinations et fenêtres ; éviter les listes blanches globales.

Faux négatifs

Quatre transferts VPN importants (6 629–7 617 Mo), **trois activités internes sur trois comptes** et **deux connexions externes réussies sur un compte** restent invisibles à l'union. L'arbre juge ordinaires leurs faibles nombres de comptes et leurs durées ; Isolation Forest ne franchit pas son seuil. Leur étiquette établit l'erreur dans le kit, sans fournir tout le scénario d'attaque. Ajouter à ce bilan quatre attaques exclues faute de volume : le rappel de 95,73 % porte uniquement sur les lignes conservées.

Limites et pistes

- **Apprentissage court** : deux semaines représentent mal les rôles nouveaux, variations saisonnières et attaques inédites. Collecter davantage de périodes et contextualiser VPN, proxy, sauvegardes.

- **Étiquettes** : les décisions de Hugo sont la référence du TP ; erreurs, retards ou désaccords modifieraient les métriques. Faire relire les cas ambigus et conserver leur provenance.

- **Agrégation horaire** : les séquences, destinations et comportements par identité manquent. Étudier des fenêtres glissantes, ratios et historiques de comptes, avec contrôle de disponibilité à la prédiction.

- **Collecte et dérive** : suppressions, unités et nouvelles infrastructures affectent couverture et faux positifs. Suivre manques, volumes d'alertes et erreurs qualifiées.

- **Évaluation exploratoire** : octobre a déjà été examiné ; ne pas optimiser puis présenter ce même mois comme test indépendant. La répétabilité locale est vérifiée ; deux relances identiques dans la VM restent à documenter.

Piste du notebook 02, section 7 : entraîner sur septembre et première semaine d'octobre, tester sur la seconde. **Expérience non exécutée ici** ; cette seconde semaine étant déjà connue, confirmer ensuite sur une période future intacte. Comparer charge, rappel par profil et couverture avant de retenir un réentraînement ou de nouveaux réglages.

Résistance aux attaques

À compléter après la séquence 4.6. Aucun résultat d'extraction, de contournement ou d'empoisonnement établi à ce stade.

Conditions d'exploitation

À compléter après la séquence 4.8. Avis provisoire du matin : observation supervisée, sans action automatique ; arbitrage RSSI/SOC sur charge et couverture avant mise en service.

Preuves : script detection_ssh_v2.py, dépendances, CSV de 239 alertes, preuves/execution_v2.txt et preuves/verification_v2.json. Deux captures du 22/10 attestent les sorties dans la VM sous le nom detection_sshv2.py ; elles ne prouvent pas l'identité des fichiers par empreinte. Les notebooks exécutés restent à récupérer. Référence : kit apprenant, section 4.4 ; détail des erreurs et captures dans la fiche 4.3 du mémo.

Annexe — Vulnérabilités et exploitation

Analyse prospective : ces scénarios ne sont pas des attaques exécutées. Les résultats des séquences 4.6 et 4.8 ne sont pas anticipés.

Vulnérabilité possible	Mécanisme et réduction proposée
Contournement	Un adversaire peut rester proche des usages ordinaires : peu de comptes, rythme lent, transferts répartis. Les FN observés montrent un angle mort, sans prouver un contournement volontaire. Corréler identité, destinations et plusieurs fenêtres.
Empoisonnement	Si des activités hostiles ou des étiquettes erronées entrent au prochain entraînement, la référence peut dériver. Séparer la collecte, faire valider les étiquettes et comparer avant/après sur un jeu conservé.
Extraction	Des scores/réponses accessibles à répétition peuvent aider à approximer les frontières. Aucun test effectué ; limiter l'accès aux scores et au modèle, journaliser les consultations.
Intégrité des artefacts	Un script ou modèle modifié peut altérer la détection. Versionner les sources, vérifier leur provenance et comparer les empreintes à une référence approuvée avant usage. Aucun chargement du joblib dans cette preuve.

Conditions proposées à faire approuver par Nadia et le SOC

• Mode d'observation local uniquement ; aucun blocage ou changement de compte automatique. Un analyste qualifie et conserve sa décision, avec escalade selon les procédures d'incident existantes.

• Avant chaque lot : vérifier schéma, unités, période, valeurs et manques ; arrêter si le contrôle échoue. Documenter les lignes exclues. Le seuil pédagogique de 10 % doit être arbitré, sans valoir autorisation implicite de perdre 10 % des événements.

• Réserver une capacité effective de qualification ; tant que 104/135 alertes dépassent 30 par semaine, traiter regroupement, priorités et renfort plutôt que masquer le surplus. Suivre le stock non lu et son ancienneté.

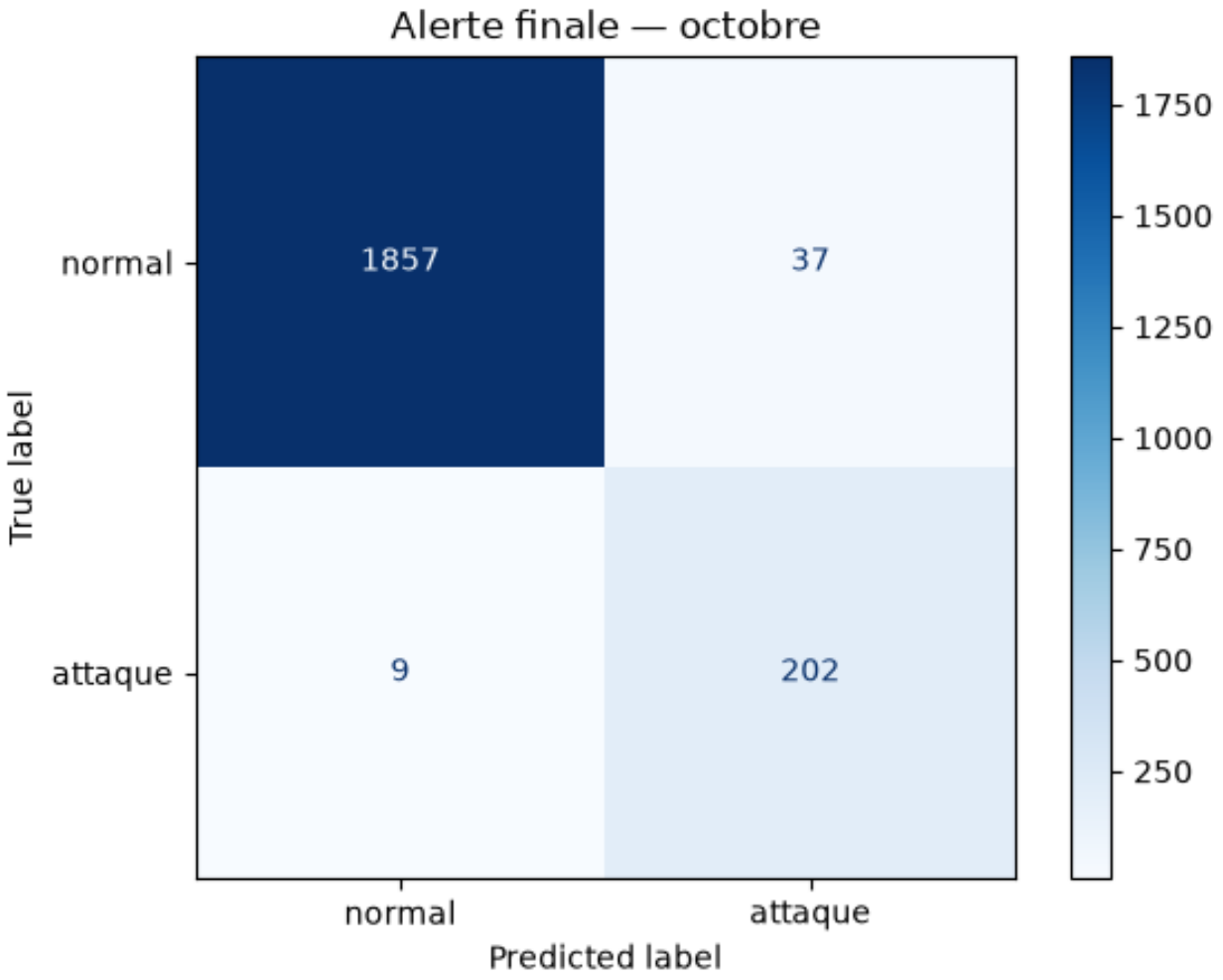
• Garder fail2ban et les autres contrôles ; mesurer FP/FN par profil sur les décisions du SOC. Réexaminer après changement de sonde, VPN ou rôle machine, incident manqué, rupture de collecte ou dérive durable des alertes.

• Réentraîner seulement sur données/étiquettes validées ; conserver une période future intacte pour tester la nouvelle version, versionner et prévoir le retour à la version précédente. Restreindre l'accès aux journaux et exports C2 ; fixer conservation et habilitations avant production.

Ces conditions sont des propositions documentaires ; leur adoption et leur efficacité ne sont pas établies par ce PDF.

Annexe — Matrice de confusion

Capture du notebook : 1 857 VN, 37 FP, 9 FN, 202 VP sur les 2 105 observations conservées.



Annexe — Exécution dans la VM

Lancement depuis ~/ia01-j4, environnement activé ; paramètres 42 / 3 / 0,03 et règles de l'arbre. Nom utilisé dans la VM : detection_sshv2.py.

```
(.venv) oliv@debian:~/ia01-j4$ python detection_sshv2.py
Graine=42, profondeur=3, contamination=0.03
hexalp_ssh_sept2026.csv : 1704 brutes ; 90 sans volume après conversion
hexalp_ssh_oct2026.csv : 2119 brutes ; 14 sans volume après conversion
|--- comptes_distincts <= 3.50
|   |--- duree_session_min <= 0.50
|   |   |--- class: 1
|   |--- duree_session_min >  0.50
|   |   |--- duree_session_min <= 64.00
|   |   |   |--- class: 0
|   |   |--- duree_session_min >  64.00
|   |   |   |--- class: 1
|--- comptes_distincts >  3.50
|   |--- externe <= 0.50
|   |   |--- heure <= 19.50
|   |   |   |--- class: 1
|   |   |--- heure >  19.50
|   |   |   |--- class: 0
|   |--- externe >  0.50
|   |   |--- class: 1


Arbre, contrôle septembre : VN=453 FP=0 FN=4 VP=28
              precision    recall  f1-score   support

      normal     0.9912    1.0000    0.9956       453
     attaque     1.0000    0.8750    0.9333        32

    accuracy                         0.9918       485
   macro avg     0.9956    0.9375    0.9645       485
weighted avg     0.9918    0.9918    0.9915       485

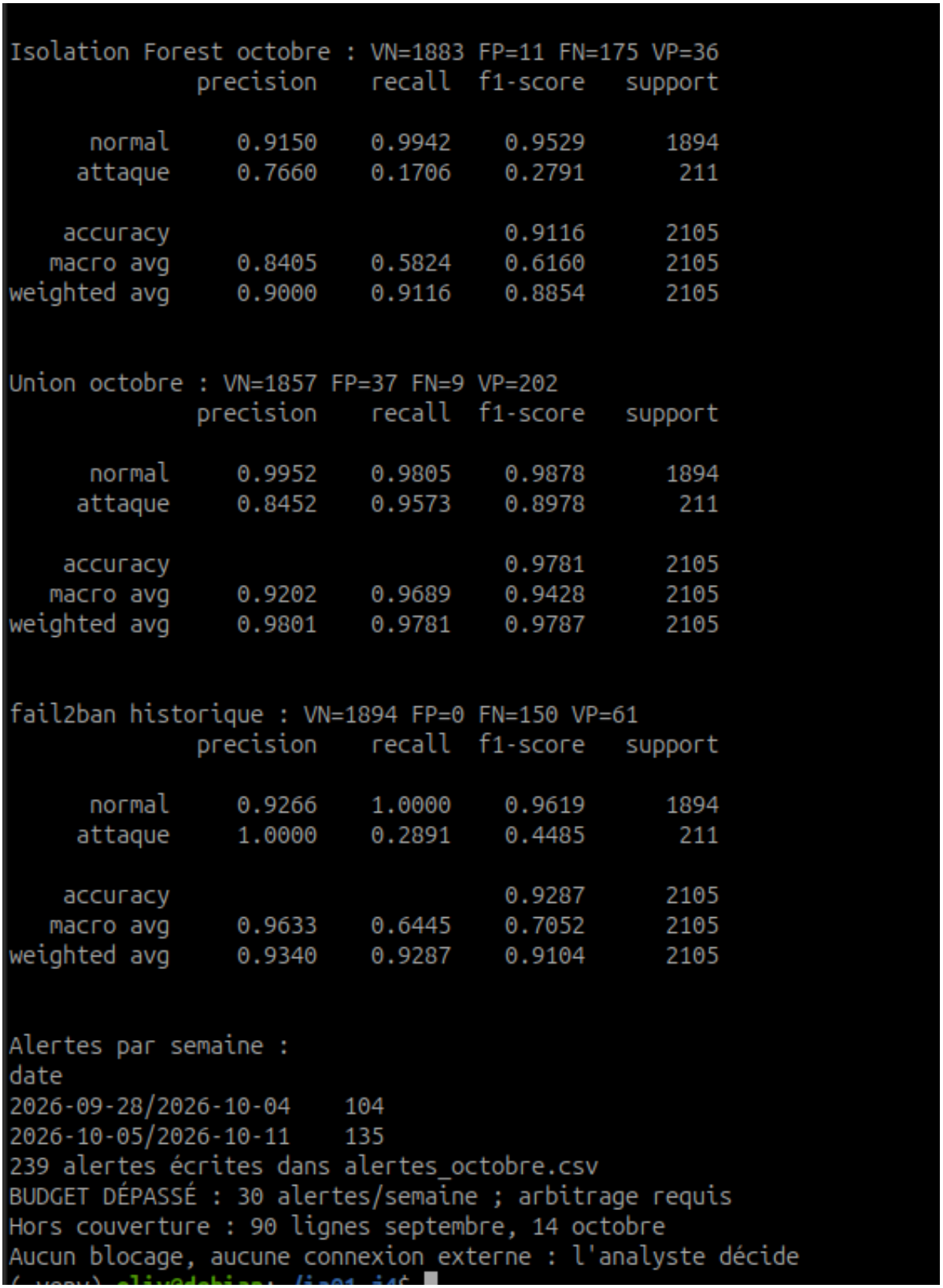

Arbre octobre : VN=1868 FP=26 FN=17 VP=194
              precision    recall  f1-score   support

      normal     0.9910    0.9863    0.9886      1894
     attaque     0.8818    0.9194    0.9002       211

    accuracy                         0.9796      2105
   macro avg     0.9364    0.9529    0.9444      2105
weighted avg     0.9800    0.9796    0.9798      2105
```

Annexe — Export et charge

Union : 239 alertes annoncées, 104 puis 135 par semaine ; budget dépassé, 90/14 lignes hors couverture. Les captures ne démontrent pas deux exécutions identiques dans la VM.



```
Isolation Forest octobre : VN=1883 FP=11 FN=175 VP=36
              precision    recall  f1-score   support

      normal     0.9150    0.9942    0.9529      1894
     attaque     0.7660    0.1706    0.2791       211

    accuracy                         0.9116      2105
   macro avg     0.8405    0.5824    0.6160      2105
weighted avg     0.9000    0.9116    0.8854      2105


Union octobre : VN=1857 FP=37 FN=9 VP=202
              precision    recall  f1-score   support

      normal     0.9952    0.9805    0.9878      1894
     attaque     0.8452    0.9573    0.8978       211

    accuracy                         0.9781      2105
   macro avg     0.9202    0.9689    0.9428      2105
weighted avg     0.9801    0.9781    0.9787      2105


fail2ban historique : VN=1894 FP=0 FN=150 VP=61
              precision    recall  f1-score   support

      normal     0.9266    1.0000    0.9619      1894
     attaque     1.0000    0.2891    0.4485       211

    accuracy                         0.9287      2105
   macro avg     0.9633    0.6445    0.7052      2105
weighted avg     0.9340    0.9287    0.9104      2105


Alertes par semaine :
date
2026-09-28/2026-10-04    104
2026-10-05/2026-10-11    135
239 alertes écrites dans alertes_octobre.csv
BUDGET DÉPASSÉ : 30 alertes/semaine ; arbitrage requis
Hors couverture : 90 lignes septembre, 14 octobre
Aucun blocage, aucune connexion externe : l'analyste décide
```